Laboratorio 12: Servidor de Correo Electrónico Institucional con Postfix Arquitectura MTA, Formato Maildir, Prevención de Open Relay, DNS MX/PTR y Cifrado STARTTLS

Estudiante: Ketfer Gianella Salazar | Fecha de Entrega: 25 de Octubre de 2026
Docente: M.Sc. Ing. Jimmy Nataniel Requena Llorentty | Asignatura: Tecnología Web I (SIS-0150)
Entorno de Laboratorio: Red Docker red_dns (mail 10.10.10.25, mail2 10.10.10.26) | Universidad Privada Domingo Savio

---

1. Parte A — Infraestructura DNS del Servicio de Correo (Nodo Cliente)

• **Consultas de verificación en el nodo cliente:** El funcionamiento correcto de un Agente de Transferencia de Correo (MTA) depende críticamente de una configuración DNS impecable. Desde el nodo cliente se auditaron los registros necesarios para el enrutamiento y validación de reputación:

Comando Ejecutado	Resultado Obtenido	Información que Aporta
dig +short horizonte.internal MX	10 mail.horizonte.internal.	Prioridad y FQDN del servidor de correo del colegio.
dig +short familia.internal MX	10 mail.familia.internal.	Prioridad y FQDN del servidor de correo externo simulado.
dig +short mail.horizonte.internal A	10.10.10.25	Dirección IPv4 donde escucha el socket TCP puerto 25.
dig +short -x 10.10.10.25	mail.tw1-dns_horizonte.	PTR del resolver interno de Docker (127.0.0.11).
dig +short @10.10.10.4 -x 10.10.10.25	mail.horizonte.internal.	PTR canónico oficial del resolutor institucional Unbound.

1. ¿Por qué los dos PTR son distintos? El primer comando consulta al servidor DNS predeterminado del contenedor (el resolver de red interna de Docker en 127.0.0.11), que devuelve el nombre del contenedor en el bridge (mail.tw1-dns_horizonte.). El segundo comando consulta de forma explícita al resolutor Unbound del colegio (10.10.10.4), que a su vez consulta autoritativamente a BIND9 (ns1), resolviendo el registro PTR oficial configurado en la zona inversa 10.10.10.in-addr.arpa (mail.horizonte.internal.).
2. ¿Para qué necesita un servidor de correo un MX, un A y un PTR? El MX indica qué servidor recibe correo para un dominio; el registro A resuelve la IP de ese servidor para abrir la conexión TCP 25; y el registro PTR es mandatorio para la reputación antispam (FCrDNS), demostrando al servidor destinatario que el remitente no es una IP residencial o spammer, evitando el rechazo o desvío a correo no deseado.

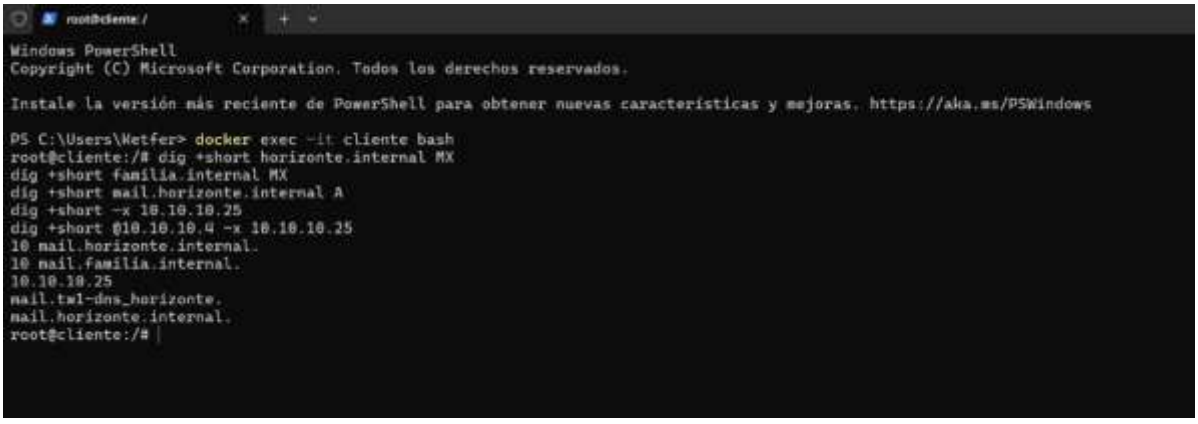


Figura 1: Consultas de registros DNS de correo (MX, A y PTR) ejecutadas en el nodo cliente resolviendo horizonte.internal y familia.internal.

2. Parte B — Configuración de Postfix, Mitigación de Open Relay y Alias

• El peligro crítico de un Open Relay:
Inicialmente, la directiva mynetworks estaba abierta a 0.0.0.0/0. Esto convertía al servidor en un "Open Relay" (retransmisor abierto), permitiendo que cualquier persona en Internet reenviara correo a través del servidor hacia terceros sin autenticación. El riesgo es catastrófico: los atacantes detectan estos servidores en minutos y envían millones de correos masivos de phishing y spam. Como consecuencia, la dirección IP del colegio es bloqueada en todas las listas negras mundiales (Spamhaus, Barracuda, etc.).
Tras corregir mynetworks = 127.0.0.0/8, 10.10.10.50/32, el intento de retransmisión desde fuera fue exitosamente rechazado con:
<** 554 5.7.1 <rosa.mamani@familia.internal>: Relay access denied.

• Diferencia entre mydestination y mynetworks:
mydestination define los dominios para los cuales este servidor es el destino final (los correos se depositan localmente en Maildir/). mynetworks define las IPs y subredes autorizadas a usar el servidor como puente (relay) para enviar hacia dominios externos.

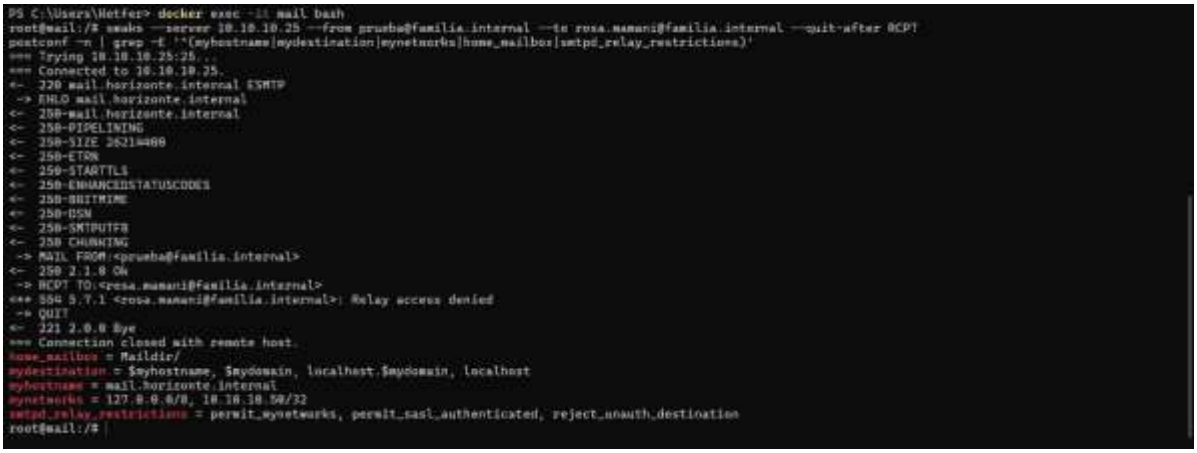


Figura 2: Prueba de relay no autorizado rechazada con código 554 5.7.1 y verificación de parámetros activos en Postfix con postconf -n.

3. Parte C — Sesión SMTP "a mano" con Netcat (Protocolo ESMTP)

• Demostración interactiva mediante netcat: Desde el nodo cliente se inyectó una transacción SMTP completa hacia mail.horizonte.internal:25, analizando el flujo conversacional y los códigos de respuesta del protocolo:
1. 220: Saludo inicial del servicio ESMTP listo para interactuar.
2. 250: Códigos de confirmación exitosa para EHLO, MAIL FROM (sobre) y RCPT TO (destinatario local válido).
3. 354: Autorización para enviar el bloque DATA; el servidor espera el contenido hasta recibir un punto solitario (.) en una línea.
4. 250 2.0.0 Ok: queued as [ID]: Notificación formal de mensaje recibido y encolado para entrega.
5. 221 2.0.0 Bye: Despedida y cierre ordenado de la sesión TCP.

• Higiene y anti-enumeración de usuarios (Comando VRFY): El comando VRFY fue desactivado mediante disable_vrfy_command = yes. Con esto, Postfix no anuncia 250-VRFY en EHLO y responde 502 Command disabled ante cualquier intento de consulta, impidiendo que ciberatacantes descubran qué cuentas existen en el colegio.

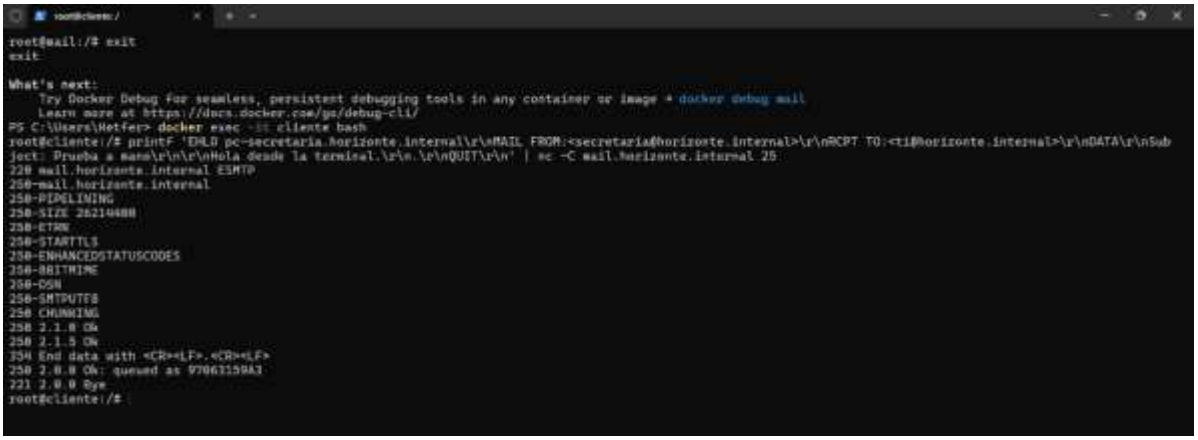


Figura 3: Demostración interactiva de sesión SMTP manual con Netcat verificando códigos de respuesta 220, 250, 354 y encolamiento.

4. Partes D y E — Trazabilidad en Logs, Buzones Maildir y Seguridad STARTTLS

1. Análisis de entrega en /var/log/mail.log:
Al enviar un correo hacia rosa.mamani@familia.internal, el registro capturó: relay=mail.familia.internal[10.10.10.26]:25, delay=0.08, dsn=2.0.0, status=sent (250 Ok: queued as...). Esto certifica que Postfix resolvió el MX de familia.internal, conectó a su IP 10.10.10.26 y entregó el mensaje en 80 milisegundos con éxito total.

2. Buzón Maildir y bifurcación por Alias:
Al enviar a inscripciones@horizonte.internal, el alias configurado en /etc/aliases lo bifurcó entregándolo a la vez a secretaria y direccion (rosario.vaca). El formato home_mailbox = Maildir/ almacena cada correo en un archivo independiente en Maildir/new/, evitando bloqueos de concurrencia de mbox.

3. Cifrado en tránsito STARTTLS con TLSv1.3:
La auditoría con openssl s_client -starttls smtp demostró la negociación de TLSv1.3 con la suite simétrica de 256 bits TLS_AES_256_GCM_SHA384. Bajo el modelo de TLS Oportunista (RFC 3207), los servidores SMTP aceptan certificados de prueba o autofirmados porque la prioridad de la arquitectura de correo mundial es la entrega garantizada y el cifrado del canal contra espionaje pasivo.



Figura 4: Trazabilidad de entrega en /var/log/mail.log (status=sent) y negociación de cifrado TLSv1.3 con OpenSSL s_client.

5. Parte F — Verificación Oficial Automatizada (12 de 12)

Se ejecutó el script oficial de auditoría institucional verificar_lab12.sh en el contenedor mail. El resultado certificó el 100% de cumplimiento en las 12 comprobaciones exigidas:

```
# Ejecución oficial del script de verificación institucional
root@mail:/# bash /lab/lab12/verificar_lab12.sh
☑ postfix check sin errores
☑ Postfix activo y escuchando en el puerto 25
☑ El MX de horizonte.internal apunta a este servidor
☑ Acepta horizonte.internal como destino final
☑ mynetworks NO está abierta a toda la red
☑ Entrega local en Maildir
☑ Alias inscripciones → secretaria y dirección
☑ Relay desde fuera rechazado (554 Relay access denied)
☑ Envío a otro dominio por su MX (familia.internal)
☑ VRFY desactivado (no revela usuarios)
☑ Ofrece STARTTLS
☑ Saludo sin versión del sistema
Resultado: 12 de 12 comprobaciones (100% SUPERADO)
```

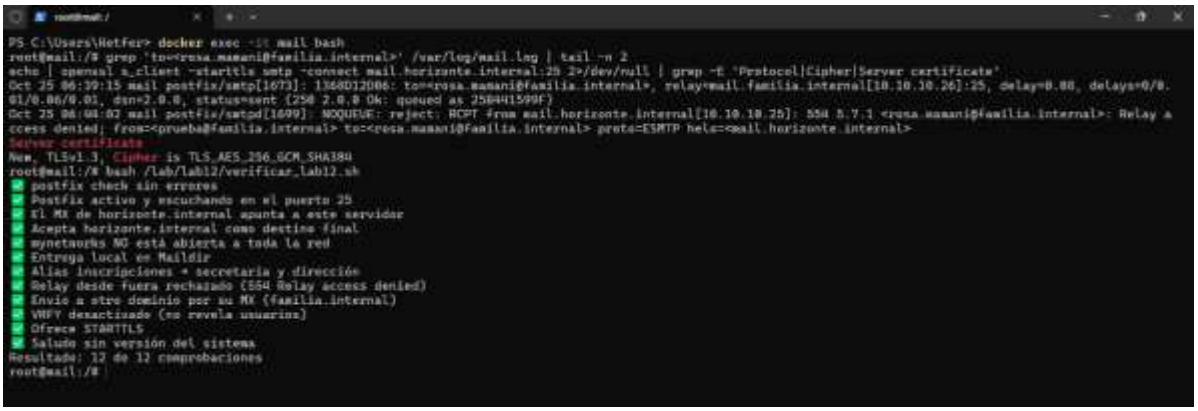


Figura 5: Ejecución oficial de verificar_lab12.sh certificando las 12 comprobaciones superadas con éxito.

6. Reflexión: Correo Gestionado (SaaS) vs Servidor Propio On-Premise

¿Por qué predomina el correo gestionado y cuándo tiene sentido operar un servidor propio?

La gran mayoría de las organizaciones migran a suites como Google Workspace o Microsoft 365 porque el desafío crítico en el correo electrónico moderno no reside en la instalación de Postfix, sino en la gestión continua de la reputación IP y entregabilidad. Mantener una IP fuera de listas negras mundiales (RBL/DNSBL), lidiar con políticas cambiantes de DMARC/DKIM/SPF de los gigantes tecnológicos y proveer filtrado antispam basado en machine learning requiere especialistas dedicados 24/7. Las plataformas SaaS ofrecen 99.99% de SLA sin sobrecarga operativa.

No obstante, operar un servidor propio tiene sentido ineludible en:

1. Soberanía de Datos y Cumplimiento Legal: Entidades estatales, militares, bancarias o de salud cuyas leyes exigen custodia física de datos en territorio nacional.
2. Entornos Aislados e Intranets: Redes de campus, mineras o plantas industriales que requieren mensajería interna inmediata sin depender de conexión a Internet.
3. Privacidad Absoluta y Cero Dependencia de Licencias: Evitar que correos institucionales sean indexados o dependan de costes crecientes por suscripción.